

PENETRATION TESTING REPORT

Project Migrasi Customer Care Claim ke AFN



PROTECT
Our Information



PRESERVE
Our Integrity



SAFEGUARD
Our Business

Document No.	: SEC-RPT-PNT-2026-08-019
Date	: August 07 ^h , 2026
Prepared By	: IT Security Department
Classification	: RESTRICTED
Distribution	: Application Development Department



INFORMATION SECURITY

We all have a role in keeping
our information safe and secure.



CONFIDENTIALITY



INTEGRITY



AVAILABILITY

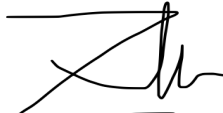


ACCOUNTABILITY

DAFTAR ISI

DOCUMENT SIGN-OFF	ii
ASSESSMENT INFORMATION.....	1
EXECUTIVE SUMMARY FINDINGS	2
TECHNICAL FINDINGS	5
1. Improper Authorization Allows Unauthorized Ticket Closure Request.	5
2. Improper Authorization Allows Unauthorized Ticket Update.	9
3. Improper Authorization Allows Unauthorized Ticket Creation with Division Manipulation.....	13
4. Email Enumeration Allows Identification of Accounting and Finance Users.	18
5. Another user can see data monitoring detail claim.	21
6. Another user can see data report detail claim.	24

DOCUMENT SIGN-OFF

TECHNOLOGY & INFORMATION SYSTEM DIVISION	SIGNATURE
Division Head Rully Harisman	
Deputy Division Head Iwan Setiawan	
IT Security Department Head Razin Haq Umran	
Team Member Seno Alrianto	
Team Member Muhamad Nanda Nugraha	

ASSESSMENT INFORMATION

IT SECURITY DEPARTMENT

Lead Penetration Tester
Razin Haq Umran

CLIENT DETAILS

Application Development Department

ASSESSMENT SCOPE SUMMARY

Engagement Timeframe

20/07/2026-05/08/2026

Engagement Scope

Web Application

Project ID: SEC-RPT-PNT-2026-08-019-v0.0

Report Date: 10/08/2026

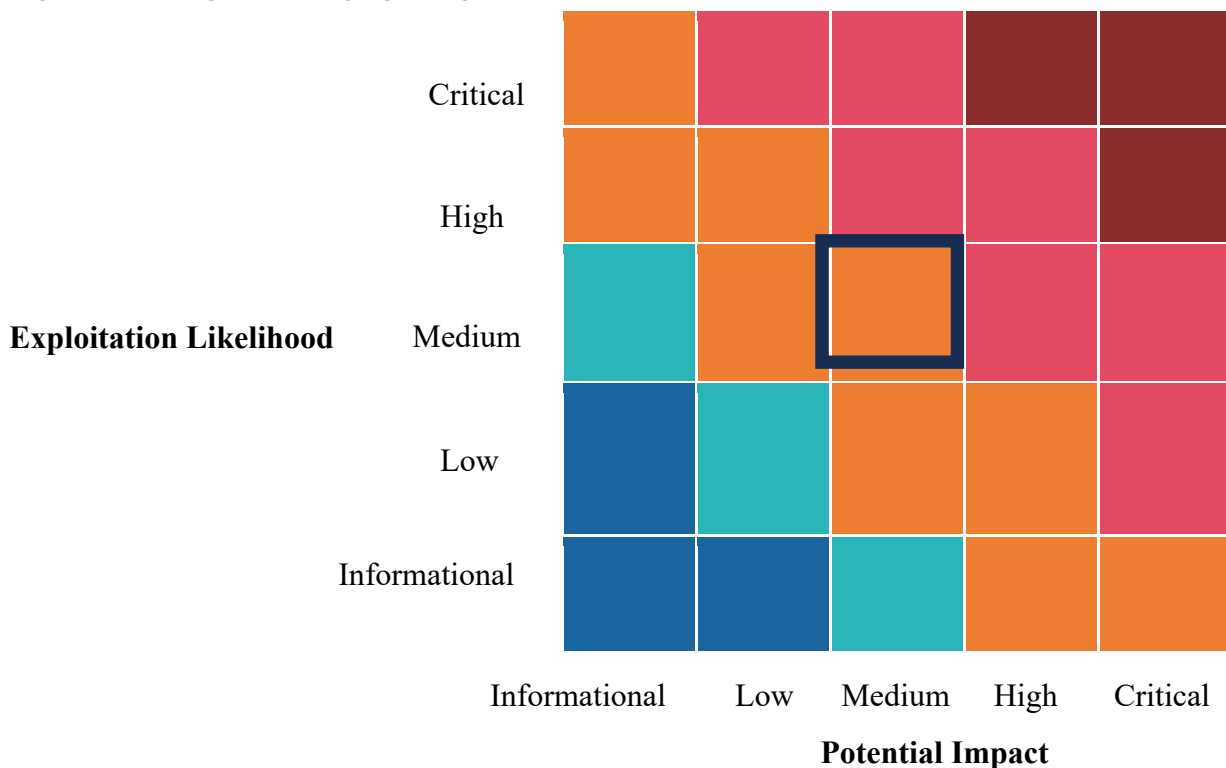
EXECUTIVE SUMMARY FINDINGS

The security assessment of the AFN BRINESIA application identified several Medium-risk vulnerabilities primarily related to Broken Access Control and Authorization weaknesses. Multiple functionalities were found to rely on client-side restrictions without adequate server-side authorization enforcement, allowing authenticated users to perform unauthorized actions such as updating ticket information, submitting ticket closure requests, and accessing claim details belonging to other users. Additionally, the authentication mechanism allows user account enumeration through distinguishable login responses. Although no critical vulnerabilities were identified, these weaknesses could compromise data integrity, expose sensitive information, and negatively impact business processes if exploited. Strengthening server-side authorization validation and implementing secure authentication practices are recommended to reduce the application's overall security risk.

AFN BRINESIA System Risk Rating

IT Security Department calculates AFN BRINESIA application risk based on Exploitation Likelihood (ease of exploitation) and Potential Impact (potential business impact to the environment).

OVERALL RISK RATING: CRITICAL



Vulnerability Summary & Report Card

0	0	6	0	0
Critical	High	Medium	Low	Informational

Finding	Severity	Description
AFN001- Improper Authorization Allows Unauthorized Ticket Closure Request.	Medium	The application does not properly enforce authorization for the Request to Close Ticket functionality, allowing unauthorized users to bypass restrictions and submit ticket closure requests due to insufficient server-side authorization validation..
AFN002- Improper Authorization Allows Unauthorized Ticket Update.	Medium	An attacker may be able to modify ticket details without proper authorization, compromising the integrity of ticket information and bypassing established business processes.
AFN003- Improper Authorization Allows Unauthorized Ticket Creation with Division Manipulation.	Medium	The application does not properly enforce authorization for the Ticket Detail Update functionality, allowing unauthorized users to bypass restrictions and modify ticket information due to insufficient server-side authorization validation.
AFN004- Email Enumeration Allows Identification of Accounting and Finance Users.	Medium	The application does not properly enforce authorization for the Ticket Detail Update functionality, allowing unauthorized users to modify ticket information.
AFN005- Another user can see data monitoring detail claim.	Medium	The application does not properly enforce authorization when accessing claim details, allowing authenticated users to access sensitive claim information belonging to other users.

AFN006– Another user can see data report detail claim.	Medium	The application does not properly enforce authorization for the Claim Detail functionality, allowing authenticated users to access other users' claim details by manipulating request parameters.
---	---------------	---

Summary of Weaknesses

The assessment identified multiple authorization and access control weaknesses within the AFN BRINESIA application. Several functionalities, including ticket updates, ticket closure requests, and claim detail access, do not properly enforce server-side authorization, allowing authenticated users to perform unauthorized actions or access information outside their permitted scope. Additionally, the authentication process discloses user enumeration information through distinguishable login responses, increasing the risk of targeted attacks against valid user accounts.

Strategic Recommendation

Strengthen server-side authorization controls by enforcing role- and ownership-based access validation for all sensitive functions and data access. Eliminate reliance on client-side restrictions as a security mechanism, implement consistent authentication error messages to prevent user enumeration, and conduct regular secure code reviews and security testing to identify and remediate access control vulnerabilities before deployment.

TECHNICAL FINDINGS

1. Improper Authorization Allows Unauthorized Ticket Closure Request.

Description:	The application does not properly validate authorization for the Request to Close Ticket functionality. As a result, unauthorized users can perform ticket closure requests by bypassing the intended application restrictions. This issue arises from insufficient server-side authorization and business logic validation, allowing restricted actions to be executed without proper permission.
Risk:	This vulnerability may allow unauthorized users to submit ticket closure requests for tickets that should not be eligible for closure. By bypassing client-side restrictions, attackers can manipulate the ticket lifecycle, resulting in unauthorized workflow changes, disruption of business processes, and potential loss of data integrity due to insufficient server-side authorization enforcement.
System:	AFN BRINESIA
Affected Host	Ticket Detail Received - AFN Brinesia
Tools Used:	Burp suite
References:	CWE-285: Improper Authorization CWE-602: Client-Side Enforcement of Server-Side Security OWASP Top 10 2021 – A01: Broken Access Control
Remediation:	Implement proper server-side authorization and business logic validation for the Request to Close Ticket functionality. The server should verify that the requesting user is authorized to perform the action and that all required business rules and ticket status conditions are satisfied before processing the request. Client-side controls, such as disabling buttons or hiding UI elements, should only be used to improve the user experience and must not be relied upon as a security mechanism. Additionally, all unauthorized requests should be rejected with an appropriate HTTP response (e.g., 403 Forbidden) and logged for security monitoring.

Reproduce steps

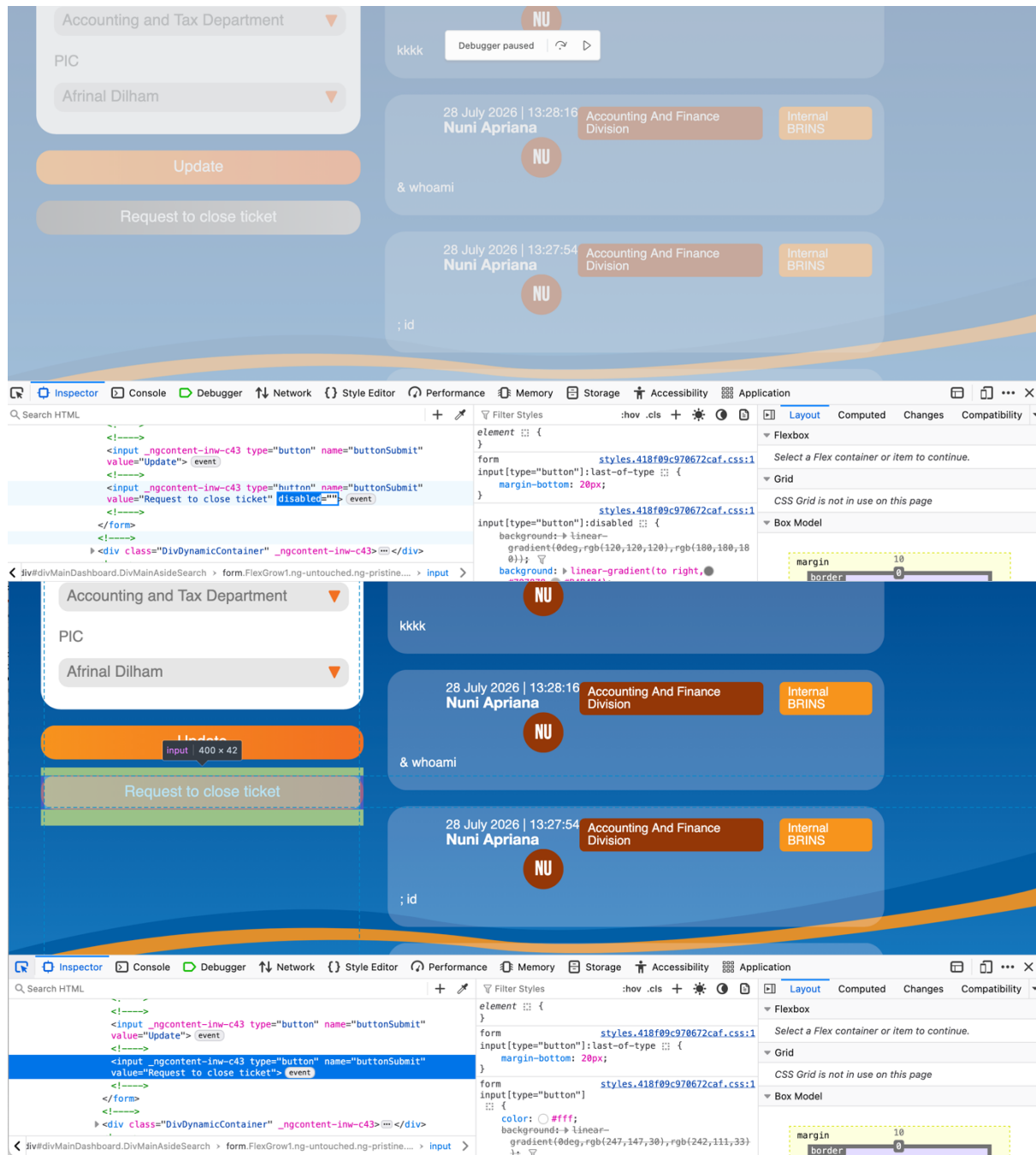
1. Open the sidebar and navigate to Ticket.
2. Select the Received submenu.
3. Open any ticket where the Request to Close Ticket button is disabled.
4. Open the browser's Developer Tools (Inspect Element).
5. Locate the Request to Close Ticket button and remove the disabled attribute from the HTML element.
6. Click the Request to Close Ticket button.
7. Observe that the application processes the ticket closure request successfully, despite the action being restricted.

Proof Of Concept (POC)



The screenshot displays the BRI Insurance ticket management interface. On the left is a sidebar with filters for 'Accounting And Finance Division', 'Assignee Branch', 'Service', 'Description', 'Department', and 'PIC'. The main area shows a list of tickets. Each ticket entry includes a timestamp, the assignee 'Nuni Apriana', a status 'NU', and a 'Request to close ticket' button. The buttons are disabled (greyed out) in the screenshot.

Timestamp	Assignee	Status	Action
28 July 2026 13:35:15	Nuni Apriana	NU	Request to close ticket
28 July 2026 13:33:18	Nuni Apriana	NU	Request to close ticket
28 July 2026 13:28:16	Nuni Apriana	NU	Request to close ticket
28 July 2026 13:27:54	Nuni Apriana	NU	Request to close ticket



Status

In Progress

Publicity

Not Shared

Asignee Division

Accounting And Finance Division

Asignee Branch

-

Service

Pendampingan Perkara Hukum

Description

test ticket help desk 2

Department

Accounting and Tax Department

PIC

Afrinal Dilham

Update

Request to close ticket

Submit

Page 1 out of 1

Row per page 20

Accounting And Finance Division

Internal BRINS

29 July 2026 | 10:04:09

Agent 1

AG

Halo Inna Putri, Terkait permasalahan pada ticket ini kami ingin memberitahukan bahwa issue pada ticket Anda telah berhasil diselesaikan oleh tim kami. Untuk itu mohon kesediaannya untuk menutup ticket ini jika sudah tidak ada hal lagi yang perlu diatasi. cara menutup ticket adalah dengan mengupdate status ticket pada dropdown status lalu klik button update. Jika dalam dua minggu tidak ada tindakan lebih lanjut, sistem kami akan menutup otomatis. Terima kasih atas perhatian dan kerjasama Anda!

28 July 2026 | 13:35:15

Accounting And Finance Division

Internal BRINS

Nuni Apriana

NU

& whoami

28 July 2026 | 13:33:18

Accounting And Finance Division

Internal BRINS

Nuni Apriana

NU

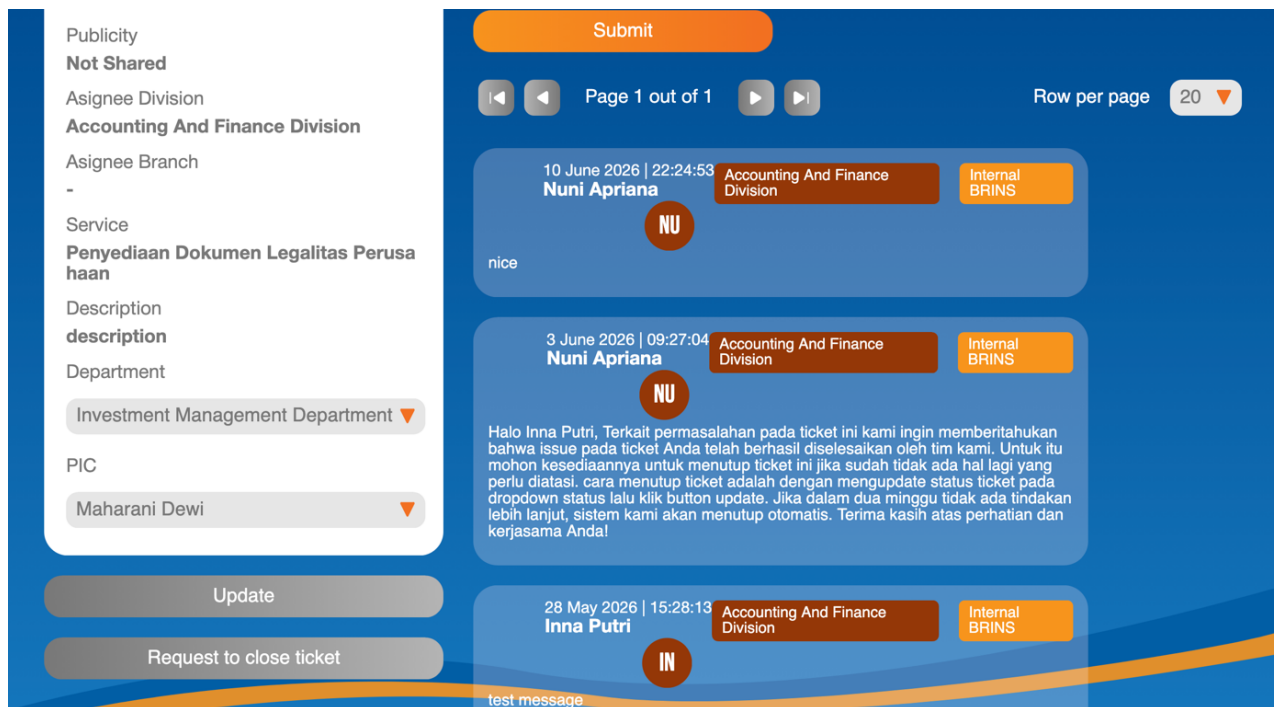
2. Improper Authorization Allows Unauthorized Ticket Update.

Description:	An attacker may be able to modify ticket details without proper authorization, resulting in unauthorized changes to ticket information and bypassing established business processes. This could compromise the integrity and reliability of the ticket management system and may lead to operational disruptions or inaccurate ticket records.
Risk:	This vulnerability may allow unauthorized users to modify ticket details by bypassing client-side restrictions. As a result, attackers could alter ticket information without proper authorization, compromising the integrity and accuracy of ticket records, disrupting established business workflows, and potentially affecting the reliability of the ticket management process.
System:	AFN BRINESIA
Affected Host	Ticket Detail Received - AFN Brinesia
Tools Used:	Burp suite
References:	CWE-285: Improper Authorization CWE-602: Client-Side Enforcement of Server-Side Security OWASP Top 10 2021 – A01: Broken Access Control
Remediation:	Implement proper server-side authorization and business logic validation for the Ticket Detail Update functionality. The server should verify that the authenticated user is authorized to modify the requested ticket and ensure that only permitted fields can be updated based on the user's role and the current ticket status. Client-side restrictions should be used solely for usability purposes and must not be relied upon as a security control. Additionally, all unauthorized update attempts should be rejected with an appropriate HTTP response (e.g., 403 Forbidden) and logged for security monitoring and auditing.

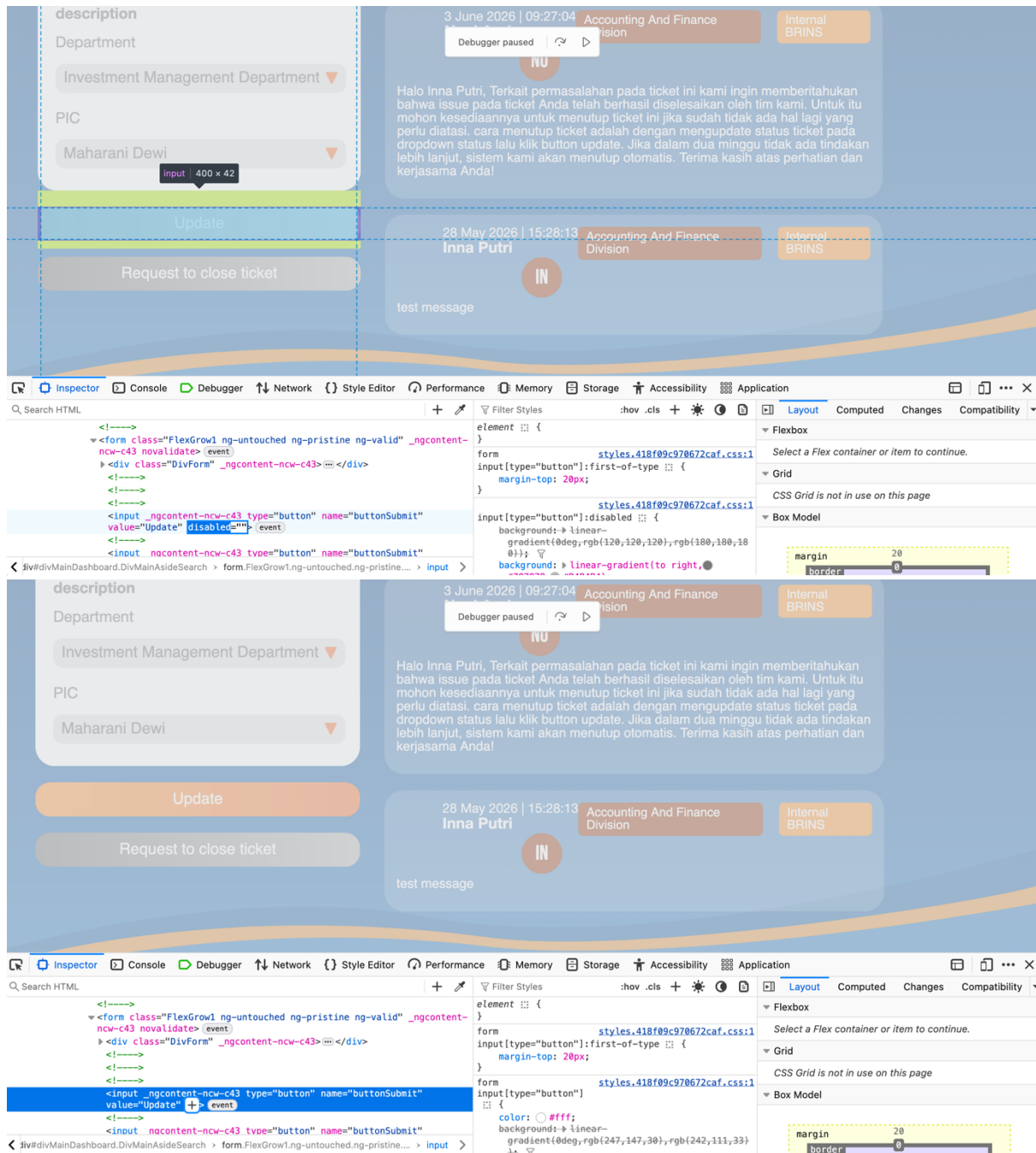
Reproduce steps

1. Open the sidebar and navigate to Ticket.
2. Select the Received submenu.
3. Open any ticket where the Update button is disabled.
4. Open the browser's Developer Tools (Inspect Element).
5. Locate the Request to Close Ticket button and remove the disabled attribute from the HTML element.
6. Click the Request to Update.
7. Observe that the application processes the ticket updated request successfully, despite the action being restricted.

Proof Of Concept (POC)



The screenshot displays the BRI Insurance Ticket Management System interface. On the left is a sidebar with filters for Publicity (Not Shared), Assignee Division (Accounting And Finance Division), Assignee Branch (-), Service (Penyediaan Dokumen Legalitas Perusahaan), Description (description), and Department (Investment Management Department). Below these are fields for PIC (Maharani Dewi) and buttons for Update and Request to close ticket. The main area shows a list of tickets with columns for date, time, assignee, division, and status. The first ticket is from Nuni Apriana on 10 June 2026, with status 'NU' and 'Internal BRINS'. The second ticket is from Nuni Apriana on 3 June 2026, with status 'NU' and 'Internal BRINS'. The third ticket is from Inna Putri on 28 May 2026, with status 'IN' and 'Internal BRINS'. A 'Submit' button is at the top right, and a 'Page 1 out of 1' indicator is below it. A 'Row per page' dropdown is set to 20. A 'test message' is visible at the bottom of the ticket list.



Not Shared

Asignee Division
Accounting And Finance Division

Asignee Branch
-

Service
Penyediaan Dokumen Legalitas Perusahaan

Description
description

Department
Investment Management Department ▼

PIC
M. Riansyah ▼

Update

Request to close ticket

Page 1 out of 1

Row per page 20 ▼

10 June 2026 22:24:53 Nuni Apriana	Accounting And Finance Division	Internal BRINS
NU nice		
3 June 2026 09:27:04 Nuni Apriana	Accounting And Finance Division	Internal BRINS
NU Halo Inna Putri, Terkait permasalahan pada ticket ini kami ingin memberitahukan bahwa issue pada ticket Anda telah berhasil diselesaikan oleh tim kami. Untuk itu mohon kesediaannya untuk menutup ticket ini jika sudah tidak ada hal lagi yang perlu diatasi. cara menutup ticket adalah dengan mengupdate status ticket pada dropdown status lalu klik button update. Jika dalam dua minggu tidak ada tindakan lebih lanjut, sistem kami akan menutup otomatis. Terima kasih atas perhatian dan kerjasama Anda!		
28 May 2026 15:28:13 Inna Putri	Accounting And Finance Division	Internal BRINS
IN test message		

3. Improper Authorization Allows Unauthorized Ticket Creation with Division Manipulation.

Description:	The application does not properly enforce authorization controls for the Ticket Detail Update functionality. Users can bypass the intended update restrictions and modify ticket information without proper server-side authorization validation. This occurs because the application relies on client-side restrictions and does not adequately verify whether the user is authorized to perform the update action.
Risk:	An attacker may be able to update ticket details without proper authorization, resulting in unauthorized modification of ticket information. This could compromise the integrity and accuracy of ticket records, bypass established business workflows, and lead to unauthorized changes that may impact operational processes and reduce the reliability of the ticket management system.
System:	AFN BRINESIA
Affected Host	Ticket Detail Create - AFN Brinesia
Tools Used:	Burp suite
References:	CWE-285: Improper Authorization CWE-602: Client-Side Enforcement of Server-Side Security OWASP Top 10 2021 – A01: Broken Access Control
Remediation:	Implement proper server-side authorization validation for the Ticket Detail Update functionality. The backend should verify user permissions and ticket ownership before processing update requests. Client-side restrictions should only be used for user experience purposes and should not be relied upon as a security control.

Reproduce steps change ticket via client side

1. Click the Ticket navbar.
2. Select the Create submenu.
3. Select any ticket record and open the Ticket Detail page.
4. Identify a ticket where the Update functionality is disabled or restricted.
5. Open the browser's Developer Tools (Inspect Element) and modify the client-side restriction to enable the update functionality.
6. Perform an update action on the ticket details.
7. Observe that the application processes the update request successfully despite the update functionality being.

Payload

```
{\"modelUserAssignee\":{\"modelDivision\":{},\"modelBranch\":{}},\"modelFormation\":{},\"listModelTicketParticipantDivision\":[{\"DivisionID\":14}],\"listModelTicketParticipantBranch\":[],\"Token\":\"3BD5952DA08070E308454FB72E3412D15AF4F9A26D15F13C02B7BDC40401B296\", \"Publicity\":false}
```

Reproduce steps change division

1. Navigate to Ticket menu and select the Create submenu.
2. Open the Ticket Detail page of an existing ticket.
3. Bypass the disabled Update functionality by modifying the client-side restriction or request.
4. Manipulate the update request by changing ticket information and the DivisionID parameter.
5. Send the request to the server.
6. Verify that the ticket is updated successfully, including the unauthorized division assignment.

Proof Of Concept (POC)

28 May 2026

Title

Test Ticket Help Desk II

Publicity

Share

Topic

Others

Status

Closed without confirmation

Assignee Division

Actuary Group

Assignee Branch

-

Service

Penyediaan Dokumen Legalitas Perusahaan

Description

description

Update

Write a message here...

Submit

Page 1 out of 1

Row per page 20

10 June 2026 | 22:24:53

Nuni Apriana

Accounting And Finance Division

Internal BRINS

NU

nice

3 June 2026 | 09:27:04

Nuni Apriana

Accounting And Finance Division

Internal BRINS

NU

Halo Inna Putri, Terkait permasalahan pada ticket ini kami ingin memberitahukan bahwa issue pada ticket Anda telah berhasil diselesaikan oleh tim kami. Untuk itu mohon kesediaannya untuk menutup ticket ini jika sudah tidak ada hal lagi yang perlu diatasi. cara menutup ticket adalah dengan mengupdate status ticket pada dropdown status lalu klik button update. Jika dalam dua minggu tidak ada tindakan lebih lanjut, sistem kami akan menutup otomatis. Terima kasih atas perhatian dan kerjasama Anda!

3 June 2026 | 09:27:04

Nuni Apriana

Accounting And Finance Division

Internal BRINS

NU

Halo Inna Putri, Terkait permasalahan pada ticket ini kami ingin memberitahukan bahwa issue pada ticket Anda telah berhasil diselesaikan oleh tim kami. Untuk itu mohon kesediaannya untuk menutup ticket ini jika sudah tidak ada hal lagi yang perlu diatasi. cara menutup ticket adalah dengan mengupdate status ticket pada dropdown status lalu klik button update. Jika dalam dua minggu tidak ada tindakan lebih lanjut, sistem kami akan menutup otomatis. Terima kasih atas perhatian dan kerjasama Anda!

28 May 2026 | 15:28:13

Inna Putri

Accounting And Finance Division

Internal BRINS

IN

test message

Penyediaan Dokumen Legalitas Perusahaan

Description

description

Update

3 June 2026 | 09:27:04

Nuni Apriana

Accounting And Finance Division

Internal BRINS

NU

Halo Inna Putri, Terkait permasalahan pada ticket ini kami ingin memberitahukan bahwa issue pada ticket Anda telah berhasil diselesaikan oleh tim kami. Untuk itu mohon kesediaannya untuk menutup ticket ini jika sudah tidak ada hal lagi yang perlu diatasi. cara menutup ticket adalah dengan mengupdate status ticket pada dropdown status lalu klik button update. Jika dalam dua minggu tidak ada tindakan lebih lanjut, sistem kami akan menutup otomatis. Terima kasih atas perhatian dan kerjasama Anda!

28 May 2026 | 15:28:13

Inna Putri

Accounting And Finance Division

Internal BRINS

IN

test message

Inspector

Console

Debugger

Network

Style Editor

Performance

Memory

Storage

Accessibility

Application

Search HTML

<form class="FlexGrow1 ng-valid ng-dirty ng-touched" _ngcontent-ncw-c43 novalidate data-gtm-form-interact-id="2"> (event)

<div class="DivForm" _ngcontent-ncw-c43> (event)

<input _ngcontent-ncw-c43 type="button" name="buttonUpdate" value="Update" disabled=""> (event)

element

form

input[type="button"]:last-of-type

form

input[type="button"]:first-of-type

input[type="button"]:disabled

margin-bottom: 20px;

margin-top: 20px;

margin: 20px 0 0 20px;

Penyediaan Dokumen Legalitas Perusahaan

Description

description

Update

3 June 2026 | 09:27:04

Accounting And Finance Division

Internal BRINS

NU

Halo Inna Putri, Terkait permasalahan pada ticket ini kami ingin memberitahukan bahwa issue pada ticket Anda telah berhasil diselesaikan oleh tim kami. Untuk itu mohon kesediaannya untuk menutup ticket ini jika sudah tidak ada hal lagi yang perlu diatasi. cara menutup ticket adalah dengan mengupdate status ticket pada dropdown status lalu klik button update. Jika dalam dua minggu tidak ada tindakan lebih lanjut, sistem kami akan menutup otomatis. Terima kasih atas perhatian dan kerjasama Anda!

28 May 2026 | 15:28:13

Inna Putri

Accounting And Finance Division

Internal BRINS

IN

test message

Inspector

Console

Debugger

Network

Style Editor

Performance

Memory

Storage

Accessibility

Application

Search HTML

<form class="FlexGrow1 ng-valid ng-dirty ng-touched" _ngcontent-ncw-c43 novalidate data-gtm-form-interact-id="2">

<div class="DivForm" _ngcontent-ncw-c43>

<input _ngcontent-ncw-c43 type="button" name="buttonUpdate" value="Update">

</div>

</div>

</form>

Filter Styles

element

form

input[type="button"]

input[type="button"]

input[type="button"]

Layout

Computed

Changes

Compatibility

28 May 2026

Title

Test Ticket Help Desk II

Publicity

Share

Topic

Information

Status

Closed without confirmation

Asignee Division

Actuary Group

Asignee Branch

-

Service

Penyediaan Dokumen Legalitas Perusahaan

Description

description

Update

10 June 2026 | 22:24:53

Nuni Apriana

Accounting And Finance Division

Internal BRINS

NU

nice

3 June 2026 | 09:27:04

Nuni Apriana

Accounting And Finance Division

Internal BRINS

NU

Halo Inna Putri, Terkait permasalahan pada ticket ini kami ingin memberitahukan bahwa issue pada ticket Anda telah berhasil diselesaikan oleh tim kami. Untuk itu mohon kesediaannya untuk menutup ticket ini jika sudah tidak ada hal lagi yang perlu diatasi. cara menutup ticket adalah dengan mengupdate status ticket pada dropdown status lalu klik button update. Jika dalam dua minggu tidak ada tindakan lebih lanjut, sistem kami akan menutup otomatis. Terima kasih atas perhatian dan kerjasama Anda!

Technology & Information System Division
SEC-RPT-PNT-2026-08-019

RESTRICTED

16

4. Email Enumeration Allows Identification of Accounting and Finance Users.

Description:	The application exposes different response messages during the authentication process based on the validity of the provided email address. An attacker can determine whether an email account is registered as an Accounting and Finance user by analyzing the login response, allowing unauthorized user account enumeration.
Risk:	This vulnerability may allow an attacker to enumerate valid user accounts by distinguishing authentication responses based on the provided email address. The disclosed information can be used to identify legitimate accounts, increasing the likelihood of targeted attacks such as credential stuffing, password spraying, brute-force attacks, or phishing campaigns against valid users.
System:	AFN BRINESIA
Affected Host	Login - AFN Brinesia
Tools Used:	Burp suite
References:	CWE-285: Improper Authorization CWE-602: Client-Side Enforcement of Server-Side Security OWASP Top 10 2021 – A01: Broken Access Control
Remediation:	The application exposes different response messages during the authentication process based on the validity of the provided email address. An attacker can determine whether an email account is registered as an Accounting and Finance user by analyzing the login response, allowing unauthorized user account enumeration.

Payload

```
{ "Culture": "en-US", "ClientDeviceType": 1, "ProjectCode": 3, "ClientPlatform": 0, "ClientOperatingSystem": "MacIntel", "ClientDeviceModel": "rv:152.0", "ServerApplicationVersion": "1.16.3", "ClientApplicationVersion": "1.1:10", "ClientDeviceID": "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:152.0) Gecko/20100101 Firefox/152.0", "UserID": 0, "Data": "{ \"Email\": \"aaaa@work.brins.co.id\" }" }
```

Reproduce steps

1. Send a POST request to the following endpoint:
POST /AccountingAndFinance/selectAccountingAndFinanceByEmail
2. Provide a valid email address in the request body parameter Data:

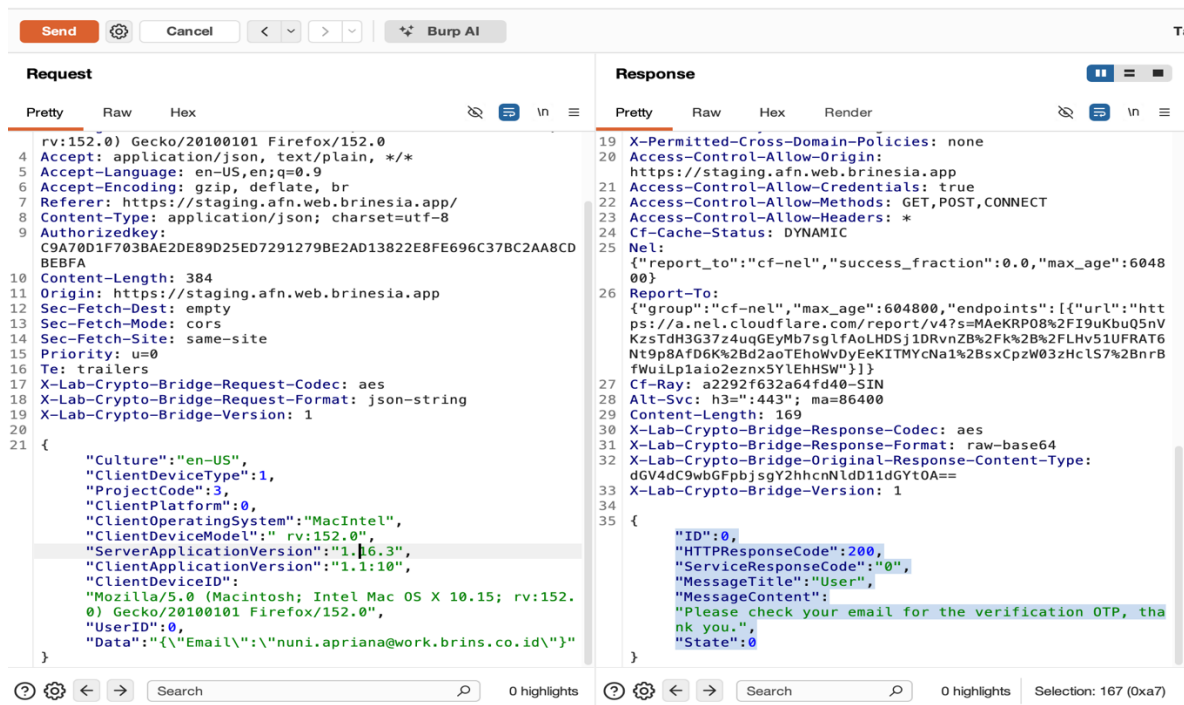
```
{
  "Email": "nuni.apriana@work.brins.co.id"
}
```

3. Observe the response returned by the server.
4. Change the email parameter to another email address that is not registered as an Accounting and Finance user:

```
{
  "Email": "invalid.mail@work.brins.co.id"
}
```

5. Send the request again and compare both responses
6. Observe that the application returns different response messages depending on whether the email address exists in the system.

Proof Of Concept (POC)



The screenshot displays the Burp Suite interface with a POST request and its corresponding response. The request is sent to the endpoint `POST /AccountingAndFinance/selectAccountingAndFinanceByEmail`. The request body contains a valid email address: `"Email": "nuni.apriana@work.brins.co.id"`. The response is a JSON object with a status of 200 and a message: `"Please check your email for the verification OTP, thank you."`. The response also includes a `"State": 0` field.

Send
Cancel
<
>
Burp AI

Ta

Request

Pretty
Raw
Hex

```

rv:152.0) Gecko/20100101 Firefox/152.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.9
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://staging.afn.web.brinesia.app/
8 Content-Type: application/json; charset=utf-8
9 Authorizedkey:
C9A70D1F703BAE2DE89D25ED7291279BE2AD13822E8FE696C37BC2AA8CD
BEBFA
10 Content-Length: 377
11 Origin: https://staging.afn.web.brinesia.app
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-site
15 Priority: u=0
16 Te: trailers
17 X-Lab-Crypto-Bridge-Request-Codec: aes
18 X-Lab-Crypto-Bridge-Request-Format: json-string
19 X-Lab-Crypto-Bridge-Version: 1
20
21 {
  "Culture":"en-US",
  "ClientDeviceType":1,
  "ProjectCode":3,
  "ClientPlatform":0,
  "ClientOperatingSystem":"MacIntel",
  "ClientDeviceModel":" rv:152.0",
  "ServerApplicationVersion":"1.16.3",
  "ClientApplicationVersion":"1.1:10",
  "ClientDeviceID":
  "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:152.
  0) Gecko/20100101 Firefox/152.0",
  "UserID":0,
  "Data":{"Email":"","xxxxx@work.brins.co.id"}
}
          
```

Response

Pretty
Raw
Hex
Render

```

19 X-Permitted-Cross-Domain-Policies: none
20 Access-Control-Allow-Origin:
https://staging.afn.web.brinesia.app
21 Access-Control-Allow-Credentials: true
22 Access-Control-Allow-Methods: GET,POST,CONNECT
23 Access-Control-Allow-Headers: *
24 Cf-Cache-Status: DYNAMIC
25 Nel:
{"report_to":"cf-nel","success_fraction":0.0,"max_age":6048
00}
26 Report-To:
{"group":"cf-nel","max_age":604800,"endpoints":[{"url":"htt
ps://a.nel.cloudflare.com/report/v4?s=kfvNsC1fwLYer38c0u2R]
AALlbIqWFEkm2xthob3oQPXqAtRMTIMn%2FYev%2FF9%2FEF%K0uMtQ5PdG
m5iIMt0yWkz%2FG8WLUoCmPL80dgXDWYVqXD4ZFbEIXq9P1ULByG%2F5Q0g
xVOYM5xLaT9emXVU3Uy"}]}
27 Cf-Ray: a2297f21ade8f8da-SIN
28 Alt-Svc: h3=":443"; ma=86400
29 Content-Length: 199
30 X-Lab-Crypto-Bridge-Response-Codec: aes
31 X-Lab-Crypto-Bridge-Response-Format: raw-base64
32 X-Lab-Crypto-Bridge-Original-Response-Content-Type:
dGV4dC9wbGFpbjsqY2hhcnNldD11dGYt0A==
33 X-Lab-Crypto-Bridge-Version: 1
34
35 {
  "ID":0,
  "HTTPResponseCode":200,
  "ServiceResponseCode":"2340101",
  "MessageTitle":"User",
  "MessageContent":
  "Email is not registered as Accounting And Finance Div
  ision based on SIMSDM database.",
  "State":0
}
          
```

?
←
→
Search
0 highlights

?
←
→
Search
0 highlights

5. Another user can see data monitoring detail claim.

Description:	The application does not properly enforce authorization controls when accessing claim details. An authenticated user can access claim information belonging to another user without proper authorization validation. The exposed claim details may include sensitive information such as email addresses, uploaded documents, and address information.
Risk:	An attacker may be able to access claim details belonging to other users, resulting in the unauthorized disclosure of sensitive information such as email addresses, uploaded documents, and address information.
System:	AFN BRINESIA
Affected Host	Monitoring detail claim - AFN Brinesia
Tools Used:	Burp suite
References:	CWE-639: Authorization Bypass Through User-Controlled Key CWE-285: Improper Authorization OWASP Top 10 2021 – A01: Broken Access Control
Remediation:	Implement proper server-side authorization checks on the Claim Detail functionality to ensure users can only access claim records that belong to their authorized scope. The application should validate the user's permission and ownership of the requested claim before returning any sensitive information.

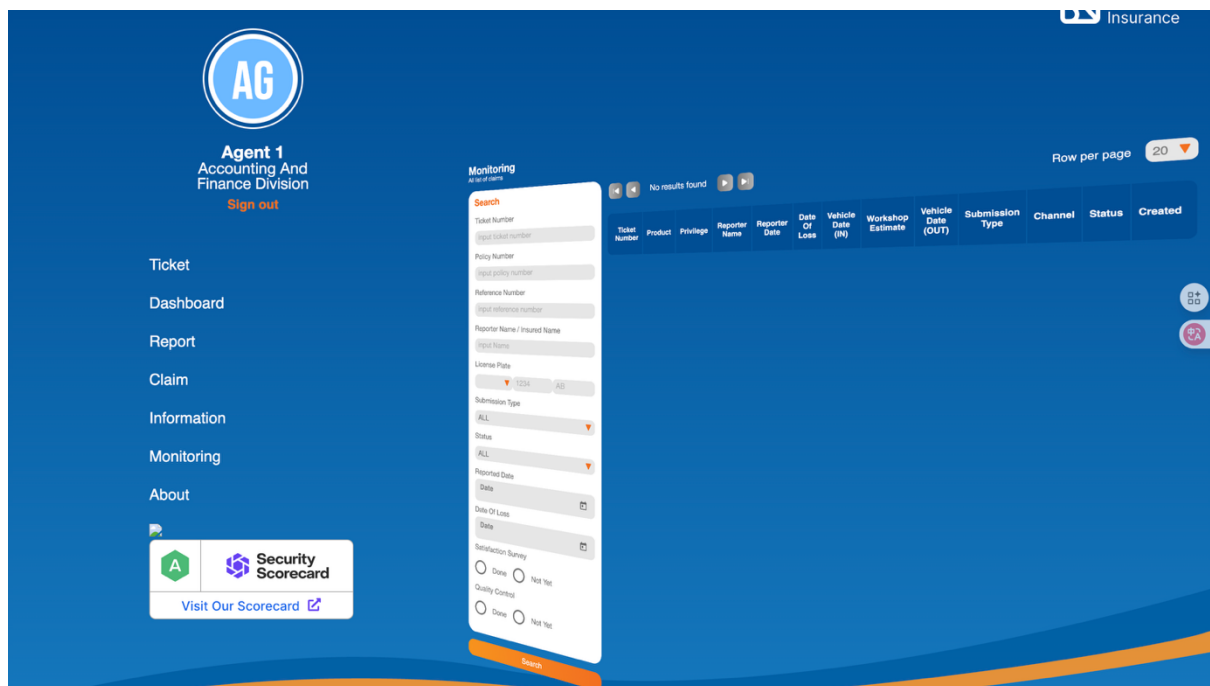
Reproduce steps

1. Login to the application using a valid user account.
2. Navigate to the Monitoring menu.
3. Open any monitoring detail page and capture the request URL containing the token parameter:

<https://staging.afn.web.brinesia.app/home/monitoring/detail/:token>

4. Replace the token value with another valid token belonging to a different user or claim record.
5. Send the modified request to the server.
6. Observe that the application successfully displays the monitoring detail information belonging to another user.

Proof Of Concept (POC)





Agent 1
Accounting And
Finance Division
[Sign out](#)

- Ticket
- Dashboard
- Report
- Claim
- Information
- Monitoring
- About


[View our Website
SECURITY REPORT](#)


[Security
Scorecard](#)

[Visit Our Scorecard](#)

Monitoring - Monitoring Detail
Policy Customer Submission Survey Summary History Tracking Adjustment Document

Policy Information

Policy Holder Name
Rayhan Muhammad

Policy Number
1115021120000001556

Reference Number
BND30200230000714

Product
Asuransi BRING OTOMAXY

Privilege
-

Branch
KANTOR CABANG UTAMA

Relationship Manager
-

Start Date
14 July 2026

End Date
14 July 2027

Policy Payment Date
14 July 2026

History Policy

New

Payment Type
Full Payment

Status
[Active](#)

Policy Active Status
[Active](#)

Policy Period Status
[On Period](#)

Policy Payment Status
[Paid](#)

Policy Grace Period Status
[No](#)

Premium
Rp. 1.562.200

Coverage Information

List Coverage

☒ Risk Coverage

☐ Sum Insured

☐ Clauses

☐ Deductible

Risk Coverage
Comprehensive
Earthquake (Motor Vehicle) OTOMAXY
Flood (Motor Vehicle) OTOMAXY
PA Passenger
PA Driver
RSCC
Third Party Liability
Terrorism & Sabotage



Agent 1
Accounting And
Finance Division
[Sign out](#)

- Ticket
- Dashboard
- Report
- Claim
- Information
- Monitoring
- About


[View our Website
SECURITY REPORT](#)


[Security
Scorecard](#)

[Visit Our Scorecard](#)

Monitoring - Monitoring Detail
Policy Customer Submission Survey Summary History Tracking Adjustment Document

Policy Information

Policy Holder Name
Rayhan Muhammad

Policy Number
1115021120000001556

Reference Number
BND30200230000714

Product
Asuransi BRING OTOMAXY

Privilege
-

Branch
KANTOR CABANG UTAMA

Relationship Manager
-

Start Date
14 July 2026

End Date
14 July 2027

Policy Payment Date
14 July 2026

History Policy

New

Payment Type
Full Payment

Status
[Active](#)

Policy Active Status
[Active](#)

Policy Period Status
[On Period](#)

Policy Payment Status
[Paid](#)

Policy Grace Period Status
[No](#)

Premium
Rp. 1.562.200

Coverage Information

List Coverage

☒ Risk Coverage

☐ Sum Insured

☐ Clauses

☐ Deductible

Risk Coverage
Comprehensive
Earthquake (Motor Vehicle) OTOMAXY
Flood (Motor Vehicle) OTOMAXY
PA Passenger
PA Driver
RSCC
Third Party Liability
Terrorism & Sabotage

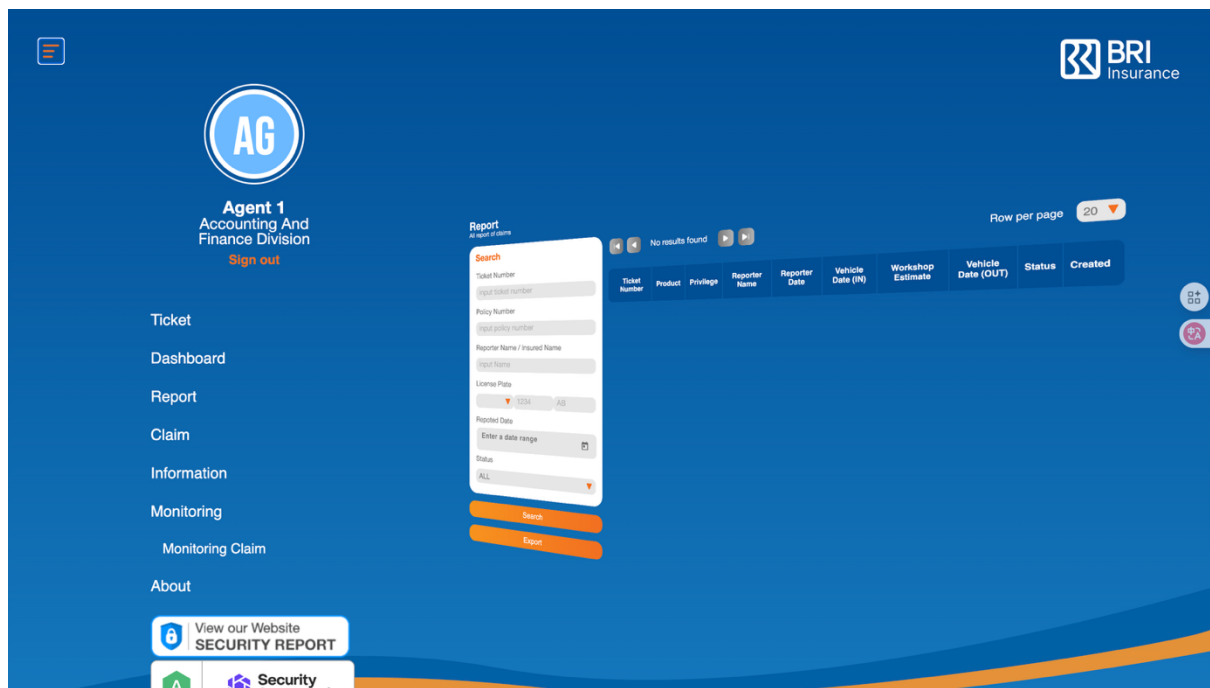
6. Another user can see data report detail claim.

Description:	The application does not properly enforce authorization checks when accessing the Claim Detail functionality through the Reporting menu. An authenticated user can access claim details belonging to another user by manipulating the request parameter without proper server-side authorization validation. As a result, sensitive information, including personal data and claim-related documents, may be exposed to unauthorized users.
Risk:	An attacker may be able to access claim details belonging to other users, resulting in the unauthorized disclosure of sensitive information such as email addresses, uploaded documents, and address information.
System:	AFN BRINESIA
Affected Host	Report detail claim - AFN Brinesia
Tools Used:	Burp suite
References:	CWE-639: Authorization Bypass Through User-Controlled Key CWE-285: Improper Authorization OWASP Top 10 2021 – A01: Broken Access Control
Remediation:	Implement proper server-side authorization checks to ensure users can only access claim records within their authorized scope. Validate the ownership or access permissions of each requested claim before returning any data. Additionally, avoid relying on user-controlled parameters without authorization validation and return an appropriate error response (e.g., 403 Forbidden) when unauthorized access is detected.

Reproduce steps

1. Login to the application using a valid user account.
2. Navigate to the Reporting menu.
3. Open any claim record and access the Claim Detail page.
4. Capture the request or URL containing the claim token.
5. Replace the token parameter with another valid token belonging to a different user's claim.
6. Submit the modified request to the server.
7. Observe that the application returns the claim details of another user without properly validating the authenticated user's authorization.

Proof Of Concept (POC)








Agent 1
Accounting And
Finance Division
[Sign out](#)

Reporting - Reporting Detail

[New](#)
[Customer](#)
[Submission](#)
[Surety](#)
[Summary](#)
[History](#)
[Tracking](#)
[Adjustment](#)
[Document](#)

Ticket

Dashboard

Report

Claim

Information

Monitoring

About

Policy Information

Policy Holder Name	Ta Fadiah Mulyadi Testing
Policy Number	115020210000000018
Reference Number	RII POLIS TESTING DOANG
Product	POLIS
Packaging	-
Search	KANTOR CABANG UTAMA
Relationship Manager	-
Start Date	27 July 2026
End Date	27 July 2027
Policy Payment Date	27 July 2026

History Policy

History Policy	New
Payment Type	Full Payment
Status	Active
Policy Active Status	Active
Policy Period Status	On Period
Policy Payment Status	Paid
Policy Grace Period Status	No
Premium	Rp. 5.000.000

[View our Website](#)

SECURITY REPORT

[Visit Our Scorecard](#)

Security Scorecard

Coverage Information

☒ List Coverage
☒ Risk Coverage
☐ Sum Insured
☐ Clause
☐ Deductible

Risk Coverage Comprehensive



CONTACT US AT
sec-tsi@work.brins.co.id